ZKProof-eKYC: Privacy-Preserving UPI

Payment Tier Eligibility using Zero-Knowledge Proofs

A Multi-Predicate Framework for India's Payment Infrastructure

Tanishq Sahu — Dr. Puneet Bakshi — Pranali Nikam

BITS Pilani, KK Birla Goa Campus — C-DAC, Pune

`zkproof-ekyc-circuits` — Privacy-Preserving DPI Infrastructure

The Problem: KYC Creates a Privacy Catastrophe

UPI KYC Infrastructure Today

- 14 billion monthly txns across 300M active users.
- Regulated via rigid tiers (No KYC, Min KYC, Full KYC).
- Unlocking limits requires surrendering PAN, Aadhaar, and income proofs to PSPs (GPay, PhonePe).
- **High-value honeypots** (e.g., MobiKwik breach).

DPDP Act 2023 Violation

Section 8(3) mandates strict **data minimisation**.

KYC verification only requires a boolean answer ("Does this user qualify?").

Collecting entire plaintext dossiers structurally violates this mandate.

The Gap in Literature

Prior ZKP identity work focuses on generic authentication. **No prior work maps ZKPs to payment system tier access control** or complex national regulatory stacks.

Our Solution: ZKProof-eKYC Framework

Conceptual Reframing

Eligibility is not data to be disclosed, but a **property to be proved**.

Instead of transmitting documents, the user's device generates a succinct 1.5 KB Groth16 zk-SNARK asserting tier eligibility.

- PSP verifies proof in ≈96 ms.
- Receives only a boolean output.
- **No personal data is ever stored.**

Key Architectural Novelties

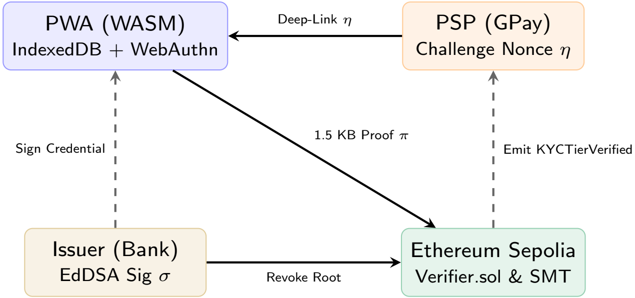
First ZKP framework for payment tiers.

- **Dual-Document Commitment**
  Protects raw PAN/Aadhaar hashes
- **Branch-Free Tier Math**
  Computes limits within scalar field
- **Real-Time Revocation**
  Depth-20 Sparse Merkle Tree (SMT)
- **Gasless Execution**
  EVM verification via ERC-4337

Multi-Predicate Engine

The circuit simultaneously evaluates 11 distinct regulatory predicates (ϕ_{age} through ϕ_{tier}) within ≈25,000 R1CS constraints.

System Architecture: Mobile Prover to EVM State



Client Trust Domain
Private witness w stays locally encrypted via biometrics.

Off-Chain Issuance
Bank builds Merkle tree and signs root via Baby Jubjub.

Trustless Verification
ERC-4337 Paymaster abstracts gas; verifier logs audit trail.

Solving Conflicting Regulations: Dual-Document Commitment

The Regulatory Conflict

RBI Para 13(c): Mandatory PAN verification for $>$ Rs.50k limits.

Aadhaar Act S.29: Absolute prohibition on transmitting or sharing the raw numeric identifier.

The R1CS Leakage Threat

If raw identifier strings enter the Circom circuit directly, they risk exposure via memory side-channels or malicious circuit forks.

The Double-Hash Solution

We evaluate a depth-3 Poseidon Merkle tree. Raw identifiers are hashed **off-circuit** by the client.

$$\mathbf{C}_{\text{pan}} = \text{Poseidon}(\texttt{PAN}, s_p)$$
$$\mathbf{C}_{\text{aadhaar}} = \text{Poseidon}(\mathrm{SHA256}(\texttt{Aadhaar}), s_a)$$

The R1CS circuit only verifies inclusion paths:

$$\phi_{\text{pan}} := \text{VerifyPath}(L_3, \pi_{\text{pan}}, R) = 1$$

Raw digits never exist within the ZKP constraints.

Branch-Free Tier Classification Logic

The Challenge with ZKP Arithmetic

- R1CS circuits cannot execute standard `if/else` branching on private signals.
- To dynamically route users to NPCI tiers (0, 1, or 2), we must use root-finding polynomials and strict boolean products.

Finite Field Safety

- To prevent malicious provers from causing underflow (e.g., claiming birth year $p - 5$), we strictly enforce bit-decomposed limits:
- $\phi_{\text{age}} := (\text{age} \geq 18) \wedge (\texttt{birthYear} \geq 1900)$

Tier Evaluation Constraints

We compute boolean flags for Full KYC (F) and Min KYC (M) via predicate multiplication:

$$F = \phi_{\text{age}} \cdot \phi_{\text{inc}}^{\text{full}} \cdot \phi_{\text{pan}} \cdot \phi_{\text{aadhaar}} \cdot \phi_{\text{pep}}$$

$$M = \phi_{\text{age}} \cdot \phi_{\text{inc}}^{\text{min}} \cdot \phi_{\text{doc}}$$

The numeric tier is then generated purely via algebraic addition:

$$\text{Tier} = 2F + (1 - F)M$$

Finally, we enforce Tier $\geq$ `Threshold` and `TxAmount` $\leq$ `Limits`.

Performance Profiling: Production Feasibility

System Feature / Metric	Osaka eKYC (2025)	ZKPass (2025)	ZKProof-eKYC (Ours)
Application Domain	Identity Auth	Identity Auth	**Payment Tier Access**
Simultaneous Predicates	3	1	**11 (Multi-Regulatory)**
SMT Revocation (Real-Time)	No	No	**Yes (Depth-20)**
Branch-Free Tier Logic	No	No	**Yes (3-Tier)**
R1CS Constraints	$\approx$500	N/A	**24,900**
Proof Gen. (Mobile WASM)	N/A	N/A	$<$ **3,000 ms**
EVM Verification Cost	N/A	N/A	$\approx$ **242,000 Gas**

Constant Payload
Proof is strictly 1.5 KB regardless of complexity.

Constraint Efficiency
SMT Revocation consumes 61.2% of the circuit budget.

Gas Economics
$<$ $0.005 on Polygon, sponsored 100% via ERC-4337.

Formal Regulatory Mapping

Governing Body	**Statutory Requirement**	**Cryptographic Enforcement**
RBI	KYC Para 13(a) – Age Verify	ϕ_{age} via bit-decomposition
RBI	KYC Para 27 – Risk Class	ϕ_{income} root-finding polynomial
PMLA	Rule 9B – PEP Exclusion	ϕ_{pep} hard exclusion constraint
PMLA	Rule 14 – Audit Trails	Immutable Sepolia `KYCTierVerified` logs
Govt. of India	**DPDP Act S.8(3) – Minimisation**	**Perfect ZK Property ($\mathcal{D}_{\text{PSP}} = \emptyset$)**
Govt. of India	**Aadhaar Act S.29 – Isolation**	**Dual-Document Double-Commitment**

Data Minimisation Theorem

Under ZKProof-eKYC, the data payload transmitted to the PSP consists exclusively of the public input vector and the proof. Because it is mathematically impossible to process fewer than zero attributes, this framework achieves information-theoretic optimal compliance with the DPDP Act.

Dual-Circuit Architecture for Financial Inclusion

The Hardware Disparity

The UPI ecosystem spans 300 million users, ranging from flagship smartphones to low-end feature phones operating on the UPI 123PAY network. A monolithic 25,000-constraint circuit would exclude lower-income demographics.

`UPIKYCTierProof(3, 20)`

The Primary Full KYC Circuit

- ≈25,000 R1CS Constraints
- Depth-3 Credential + Depth-20 SMT
- Targets modern smartphones/web
- Execution time: ≈2.8s (Mobile)

`MinKYCTierProof(3)`

The Heavily Optimized Circuit

Designed exclusively for the Rs. 10,000 Minimum KYC tier. Omits PAN, Aadhaar, PEP checks, and the computationally heavy SMT revocation.

- ≈7,000 R1CS Constraints
- Basic Age, Income, OVD, & Sig Verify
- Execution time: <150ms (Low-end Android)

Ensures zero-knowledge privacy does not come at the cost of financial exclusion.

Cryptographic Optimization & Trusted Setup

Optimized Cryptographic Primitives

- **Poseidon Hash over SHA-256:**
  Standard SHA-256 requires ≈20,000 constraints per hash. Switching to the ZK-friendly Poseidon hash reduces this to just ≈240 constraints.
- **EdDSA on Baby Jubjub:**
  Traditional RSA-2048 signature verification requires an untenable ≈500,000 constraints. EdDSA-Poseidon over the Baby Jubjub elliptic curve compresses issuer authentication to ≈3,180 constraints.

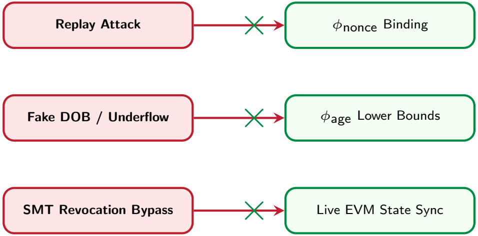
National-Scale MPC Ceremony

Groth16 relies on a one-time trusted setup (Powers of Tau). A compromised "toxic waste" (τ) allows proof forgery.

The DPI Solution:
A massive Multi-Party Computation (MPC) ceremony involving the RBI, NPCI, major PSPs, and auditors. Under the MPC security model, as long as a *single participant* destroys their entropy shard, the `circuit_final.zkey` is cryptographically secure globally.

Neutralizing Attack Vectors

- **Network Interceptor (Cross-PSP Replay):**
  An attacker intercepts a valid GPay proof and resubmits to PhonePe. **Mitigation:** ϕ_{nonce} enforces Poseidon$(\eta, R) \equiv H_{\text{bound}}$, fusing the proof to the PSP's specific 256-bit challenge.
- **Malicious Prover (Field Underflow):**
  Prover claims $\texttt{birthYear} = p - 5$ to force the math to wrap around the finite field p. **Mitigation:** Bit-decomposed lower bounds (≥ 1900) make wraparound impossible.
- **Blockchain Observer (Linkability):**
  Observer tracks EVM inputs to trace a user. **Mitigation:** Nullifier $N_c =$ Poseidon$(\texttt{ID}, \texttt{secret})$ uses a private salt. Sessions are 100% unlinkable.



Strict Functional Validation (Test Vectors)

R1CS Circuit Evaluation against Adversarial Inputs

To guarantee mathematical robustness, the circuit was validated against strict edge-case vectors. A failure in any single predicate results in an unsatisfiable polynomial system.

Adversarial Condition	**Statutory / Logical Violation**	**R1CS Result**
Valid Full KYC	All 11 predicates satisfied perfectly	**Accept**
Age Underflow Attempt	Finite field wraparound trick $(p - 5)$	**Reject**
Minor Applicant	`birthYear` $= 2010$ (Age < 18)	**Reject**
Signature Forgery	1 bit flipped in L_1 (`incClass` hash)	**Reject**
PEP Evasion	`isPEP` flag manually altered from 1 to 0	**Reject**
Expiration Limit	`issYear` $= 2013$ (> 10 year validity)	**Reject**
Revoked State	SMT Non-Membership evaluates to False	**Reject**
Cooling Breach	Request >Rs.25k within 24h of profile	**Reject**

Conclusion & Extensibility

What we built

- 25,000-constraint Circom 2.0 dual-circuit framework.
- First cryptographic mapping of NPCI payment tiers.
- PWA biometric integration & ERC-4337 smart contracts.
- Validated against 12 adversarial test vectors.

Future Work

- **Trustless Issuance:** Parse offline XML files directly via Web Crypto API, removing banks from issuance.
- **Post-Quantum:** Migrate to zk-STARKs (Poseidon-based) to remove the Groth16 trusted setup.

One Credential, Multiple Products

The depth-3 credential Merkle tree serves as a foundational base layer for the broader Indian DPI.

Through modular circuit extensions, it can authorize:

- RuPay Credit (ϕ_{cibil})
- NACH Mandates (ϕ_{balance})
- FASTag Auth (ϕ_{vehicle})

without any redundant document disclosure.

`zkproof-ekyc-circuits`

Thank you